OneDev SSH Auth Bypass to SYSTEM Access

Researcher	Kashish Topiwala
Product	OneDev (theonedev/onedev)
Affected	OneDev 16.8.7 and earlier
CWE	CWE-287 Improper Authentication
CVSS 3.1	9.1 Critical (AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:N)

Summary

OneDev is a self-hosted Git server. Its SSH authenticator sets the session identity as a side effect. If a client offers the server's own host key, the identity becomes the internal SYSTEM user, and a SYSTEM session skips all permission checks. With a custom SSH client a normal user keeps this SYSTEM identity through the login, and can then read, clone, and push every repository on the server. Self-registration is on by default, so no prior account is needed.

Steps to reproduce

1. Register an account (self-registration is on by default) and add an SSH public key.
2. Read the server's SSH host key with ssh-keyscan.
3. With a custom SSH client, offer your own key, then offer the server host key, then complete a signed login with your own key. The session identity becomes SYSTEM.
4. Clone or push any repository. The server does not check permissions for a SYSTEM session.

Impact

- A normal user, or anyone because self-registration is on, reads every repository.
- The attacker can push and force-push to every repository, which allows code injection.
- Branch protection does not stop a SYSTEM session.
- The full source code of every project is disclosed.

Remediation

- Set the session identity only after the signature is verified, and clear it on each authentication attempt, instead of as a side effect of an offered key.
- Do not match the server's own host key as a user credential on the public SSH port.
- Keep the SYSTEM and cluster authentication path on the internal cluster transport only.

References

- https://github.com/theonedev/onedev
- https://cwe.mitre.org/data/definitions/287.html